

LokiBot Analysis

Hayden Sapp and Hannah Ohm

2024-04-22

CI410: Malware Analysis Section 2

Background

LokiBot was originally developed and released in 2015 by “lokistov”—a forum name for a hacker based in ex-USSR territories [1]. It is a trojan-based malware that masquerades as other software or uses software like Microsoft Word to execute itself. After installing itself without the user’s knowledge, it will attempt to steal the user’s passwords and login credentials from various sources like FTP applications, web browsers, stored WPA passkeys, and more. First seen in 2015, LokiBot continues to be a highly prevalent and ever-evolving malware.

History

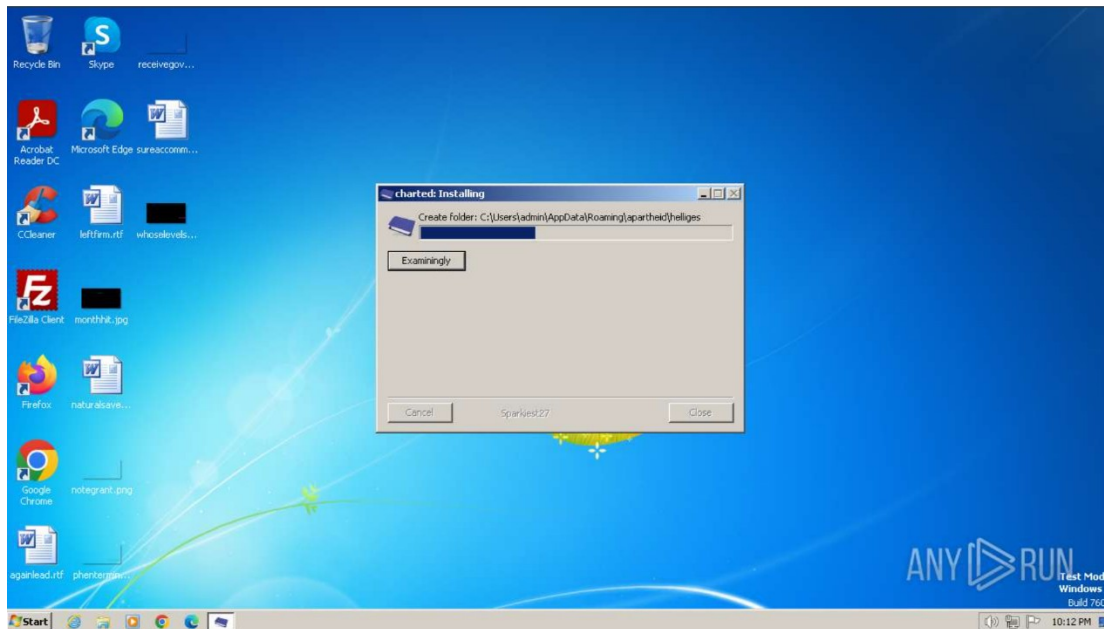
Originally released on forums in 2015, LokiBot was being sold for \$800 as an any-purpose malware [1]. Since 2018, it’s believed that lokistov was hacked and the source code to LokiBot was leaked due to independent sellers claiming they were selling LokiBot for as low as \$80 [2]. As time went on more and more sources claimed to have LokiBot and they were selling slightly different variations on the original malware. From each iteration and addition to the original LokiBot, there are numerous new malware with new ways of infection still being classified as LokiBot. Using the original framework of the LokiBot malware attackers are able to tailor it to their specific needs, however it leaves them with the same signatures and Indicators of Compromise (IOC) that the original had. Since the leak of the original source code, different forks and variations of LokiBot have increased and spread with slight changes and alterations between the way it infects and what data it steals. Reports show that variations of LokiBot have been known to exploit CVE-2022-30190, CVE-2017-11882, CVE-2021-40444, and potentially more [6]. As each attacker adds their own spin and unique aspects to the malware, specifics of the LokiBot malware can be attributed differently over time. However, the one aspect unique to LokiBot that the majority of clones use is contacting a command-and-control server with a “*fre.php*” file located on it.

Propagation Strategies

The classic LokiBot was distributed by phishing schemes using Microsoft Excel documents that would trick the user into enabling macros by blurring the images within the Excel file. Once the user enabled macros, LokiBot would exploit CVE-2017-11882, a remote code execution which would install LokiBot in the background [3]. While some sources report that the macros being enabled is what allow the remote code execution, Microsoft officially states that just opening the infected Word/Excel document can infect the host computer [4].

In altered versions of LokiBot, it will pose as an installation wizard and install the malicious software in the background, shown in figure 1. It's easy to notice the bad English and numerous command prompt windows that open during the installation of the “Charted” software that identify it as malicious. Unlike the classic LokiBot malware, this variation of the malware is spread through online sites that advertise fake software for people to download.

Figure 1



Note. This figure shows the fictitious installation wizard that installs LokiBot. Obtained and analyzed from AnyRun [5].

Tactics

Category	Tactic	Use
Execution	T1059.001	LokiBot is able to use PowerShell for command execution
Execution	T1059.003	LokiBot is able to use Windows CMD for command execution
Defense Evasion	T1027.009	LokiBot uses obfuscated and large files to hide embedded payloads
Defense Evasion	T1564.003	LokiBot will run PowerShell in hidden windows to hide the malicious commands
Discovery	T1057	LokiBot will use PowerShell to get information about processes
Discovery	T1012	LokiBot is able to read registry data, read security settings, identify server information, and the computer name

Discovery	T1082	LokiBot identifies the GUID for registry keys
Command and Control	T1132	LokiBot uses PowerShell to convert a large byte array to readable text to make traffic harder to detect.

Static Analysis Findings

Using a static analysis tool like Virus Total show that this sample of malware goes by many different names and has a multitude of signatures—which makes sense given the mass small modifications made to the original LokiBot malware. This sample of LokiBot has been used with the following names:

Name	Security Vendor
LokiBot	VBA32
Leonem	AhnLab-V3
NSIS:TrojanX-gen	Avast
Trojan.Dropper.NSIS	Malwarebytes
Makoob	Kingsoft
CLR!tr	Fortinet

The sample analyzed for this report has the following information:

Name	RFQ-SulselBarru_II_2-COAL_COMML_DOC.exe
Size (bytes)	663136
md5 hash	90fda5c072fe00e8e737606add7f1276
sha256 hash	c384d26e83f585fbadd73e6cea441d1479d68de5bb647f775b506e5eab7f3230
Compilation time	2023-07-02 02:09:39 UTC

The chart below shows the libraries and functions enumerated from the malware sample by VirusTotal.

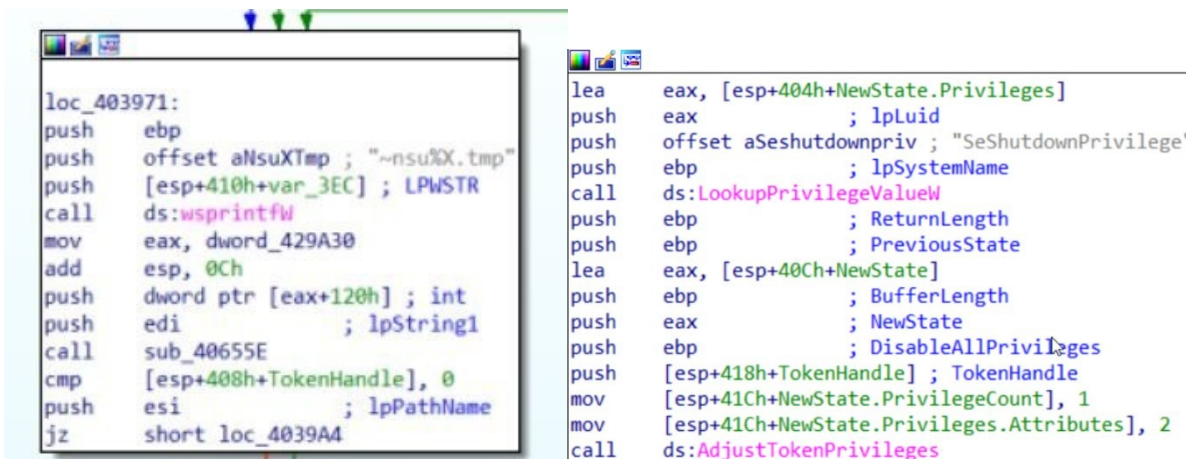
ADVAPI32.dll	AdjustTokenPrivileges LookupPrivilegeValueW OpenProcessToken RegCloseKey RegCreateKeyExW	RegDeleteKeyW RegDeleteValueW RegEnumKeyW RegEnumValueW RegOpenKeyExW
SHELL32.dll	SHBrowseForFolderW ShellExecuteExW SHFileOperationW	SHGetFileInfoW SHGetPathFromIDListW

ole32.dll	CoCreateInstance CoTaskMemFree IIDFromString	OleInitialize OleUninitialize
COMCTL32.dll	ImageList_AddMasked ImageList_Create	ImageList_Destroy Ord(17)
USER32.dll	AppendMenuW BeginPaint CallWindowProcW CharNextA CharNextW	CharPrevW CheckDlgButton CloseClipboard CreateDialogParamW CreatePopupMenu
GDI32.dll	CreateBrushIndirect CreateFontIndirectW DeleteObject GetDeviceCaps	SelectObject SetBkColor SetBkMode SetTextColor
KERNEL32.dll	CloseHandle CompareFileTime CopyFileW CreateDirectoryW CreateFileW	CreateProcessW CreateThread DeleteFileW ExitProcess ExpandEnvironmentStringsW

This sample of LokiBot imports SHELL32.dll, USERS32.dll, COMCTL32.dll, and KERNEL32.dll which contain standard functions for file deletion, file creation, window creation, command execution, and web connections. This sample poses as an installation wizard as it installs LokiBot in the background, which coincides with the imports seen in static analysis. It is also important to note that this variation of LokiBot was compiled, seen, and reported in late 2023, showing that LokiBot and its variations are still being created and exploited.

Additionally, this sample of LokiBot is a signed file with certificates signed by “*cradlefellow*”. While appearing as a trusted and signed program at first glance, this certificate terminates at the root certificate authority which is an untrusted certificate.

Figure 2



Note. This figure of IDA screenshots show the LokiBot sample changing privileges for access tokens, like the Shutdown Privilege.

The two images above in figure 2, show the assembly language of the compiled program. These show the program utilizing functions to change privileges for access tokens. Specifically, it is changing the privileges to shut down the system. In the left image, we see it accessing a temporary file “~nsuXX.tmp”, likely being used to store temporary changes to the token. In the Ghidra decompiler—shown in figure 3—there is evidence of tampering other token privileges, assigning it certain attributes.

Figure 3

```

 Stack_3e0.Privileges[0].Attributes = 2;
 AdjustTokenPrivileges(pvStack_3e4,0,&Stack_3e0,0,(PTOKEN_PRIVILEGES)0x0,(PDWORD)0x0);
 }

```

Note. This figure of a Ghidra screenshot shows the imported Windows command “AdjustTokenPrivileges”.

When enumerating the strings for the program, there are a few files that the program touches, shown in figure 4. Likely this is enumerating information about the system, such as the version information, the language, and the internet settings, which can lead to more specific changes it can make to settings and permissions.

Figure 4

00...	RichEd20	"RichEd20"
00...	.DEFAULT\Control Panel\International	u".DEFAULT\\Control Panel\\International"
00...	Control Panel\Desktop\ResourceLocale	u"Control Panel\\Desktop\\ResourceLocale"
00...	Software\Microsoft\Windows\CurrentVersion	u"Software\\Microsoft\\Windows\\CurrentVersion"
00...	Microsoft\Internet Explorer\Quick Launch	u"\\Microsoft\\Internet Explorer\\Quick Launch"
00...	...	...

Note. This figure shows the Strings search from Ghidra.

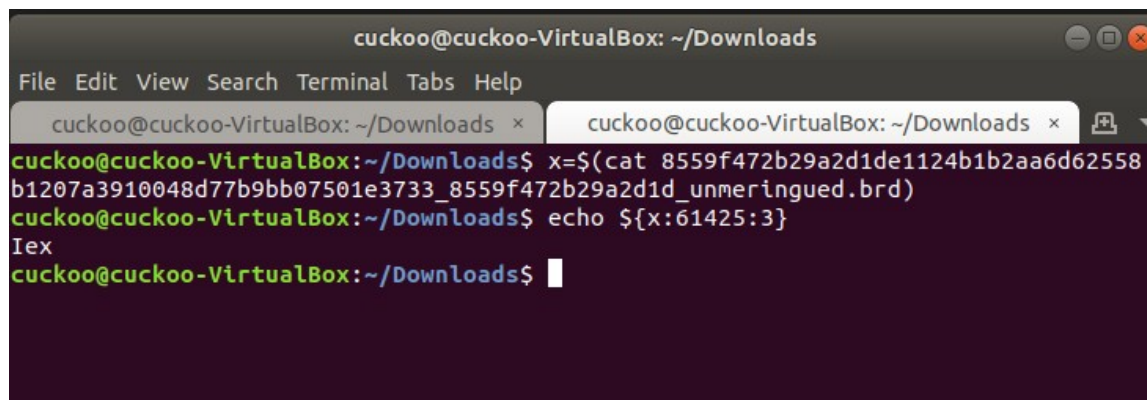
Dynamic Analysis Findings

In the variation of LokiBot that poses as an installation wizard [5] it will run the following command in the background:

```
"powershell.exe" -windowstyle hidden "$Harish116=Get-Content 'C:\Users\admin\AppData\Local\Ubarberet\Graustark\resultalet\Unmeringued.Brd';$Omkldningsrums=$Harish116.SubString(61425,3);.$Omkldningsrums($Harish116) "
```

This command runs a hidden PowerShell window that gets the contents of the dropped file *Unmeringued.Brd*—a file that has 61450 characters of ASCII text. This file is heavily obfuscated containing unreadable text, Danish words, Italian words, functions, and more. It then gets the substring of this text file from characters 61425 to 61427 and assigns it to a variable that then gets interpreted as a function. As shown in figure 5, the contents of this variable is the letters “Iex”, which is *Invoke Expression* in PowerShell. Finally, the PowerShell window will attempt an *Invoke Expression* on every function within the file. This file is likely the information transmitted between the host machine and the command-and-control server, given the identified Mitre tactic [T1132], where the above PowerShell command parses through a large data file for target Invoke-Expressions. As there are tens of thousands of characters in the file and this file is one of many files dropped during the execution of this malware, providing insightful analysis into this specific variation proves time consuming and difficult at the very *least*.

Figure 5



Note. This figure shows the output of the “*Omkldningsrums*” function from the hidden PowerShell window that the installation window makes.

One commonality on most LokiBot variants is the communication with a command-and-control server, specifically with the request to a “*fre.php*” page. Leaked source code of the *fre.php* page reveal that if the connection is not within its locally stored whitelist, it adds the IP address and connection information into an array of known infected machines [6].

Current Threat Level

As there are more and more variations of this malware everyday, it is hard to pinpoint the exact abilities of it as of today. However, Lokibot was most recently seen in news articles in mid-2023. The articles indicated that this version of Lokibot acts as a keylogger, sending crafted HTTP packets containing keystrokes. The news also indicates that it is more often found in phishing emails now, rather than impersonating software downloads. [13]

Mitigation Strategies

The Cybersecurity and Infrastructure Security Agency (CISA) developed a snort rule to detect and block any standard LokiBot activity and create an alert of the activity, as shown below [7].

Figure 3

```
alert tcp any any -> any $HTTP_PORTS (msg:"Lokibot:HTTP URI POST contains '/*fre.php' post-infection"; flow:established,to_server; flowbits:isnotset,.tagged; content:"/fre.php"; http_uri; fast_pattern:only; urilen:<50,norm; content:"POST"; nocase; http_method; pcre:"/\/(?:alien|loky\d|donep|jemp|lokey|new2|loki|Charles|sev7n|dbwork|scroll\/NW|wrk|job|five\d?|donemy|animation\dkc|love|Masky|v\d|lifetn|Ben)\/fre\.php$/iU"; flowbits:set,.tagged; classtype:http-uri; metadata:service http; metadata:pattern HTTP-P001,)
```

Note. This figure is a SNORT firewall rule that can detect LokiBot activity on a network and report it as such. Developed by CISA, received from [7].

While this snort rule won't prevent or uninstall the LokiBot software from the machine, it alerts for any requests to any *fre.php* on any website. CISA also recommends maintaining up-to-date antivirus signatures as LokiBot is an ever-evolving malware. Additionally, the ability to install and run software should be limited to only administrators to prevent the trojan horse style of LokiBot from having access to the system. Additionally, the National Institute of Standards and Technology recommends adhering to the 800-83 specifications standard which outlines malware incident response and prevention [9].

References

- [1] AnyRun, LLC. (2024). “*Malware Trends: LokiBot*”. AnyRun.com. <https://any.run/malware-trends/lokibot> (Accessed April 22, 2024)
- [2] Schwartz, M. (2023, September 14). “*LokiBot Information Stealer Packs Fresh Infection Strategies*”. BankInfoSecurity.com. <https://www.bankinfosecurity.com/lokibot-information-stealer-packs-fresh-infection-strategies-a-23079> (Accessed April 22, 2024)
- [3] Sison, G & Co, M. (2018, February 8). “*Attack Using Windows Installer Leads to LokiBot*”. TrendMicro.com. https://www.trendmicro.com/en_us/research/18/b/attack-using-windows-installer-msiexec-exe-leads-lokibot.html (Accessed April 22, 2024)
- [4] Microsoft Corporation. (2017, November 29). “*Microsoft Office Memory Corruption Vulnerability*”. Microsoft.com. <https://msrc.microsoft.com/update-guide/en-US/advisory/CVE-2017-11882> (Accessed April 22, 2024)
- [5] AnyRun, LLC. (2024). “*LokiBot Malware Task*”. Any.Run <https://app.any.run/tasks/af4c4ddf-e1d4-4cf3-b0e1-64472eaf33ce/> (Accessed April 22, 2024)
- [6] NexusFuzzy. (2019, June 12). “*Leaked LokiBot Panel*”. GitHub.com. <https://github.com/NexusFuzzy/lokibot/blob/master/fre.php> (Accessed April 21, 2024)
- [7] CISA. (2020, October 24). “*LokiBot Malware Cybersecurity Advisory*”. CISA.gov. <https://www.cisa.gov/news-events/cybersecurity-advisories/aa20-266a> (Accessed April 22, 2024)
- [8] VirusTotal. (2024). “*Static Analysis Report for c384d26e83f585fbadd73e6cea441d1479d68de5bb647f775b506e5eab7f3230*”. VirusTotal.com. <https://www.virustotal.com/gui/file/c384d26e83f585fbadd73e6cea441d1479d68de5bb647f775b506e5eab7f3230> (Accessed April 22, 2024)
- [9] NIST. (2013, July). “*Guide to Malware Incident Prevention and Handling for Desktops and Laptops*”. NIST.gov. (Accessed April 22, 2024). [Online]. Available: <https://csrc.nist.gov/pubs/sp/800/83/r1/final>, <https://doi.org/10.6028/NIST.SP.800-83r1>.
- [10] “Lokibot,” Lokibot, Software S0447 | MITRE ATT&CK®, <https://attack.mitre.org/software/S0447/>.
- [11] M. Corporation, “Microsoft,” threat description - Microsoft Security Intelligence, <https://www.microsoft.com/en-us/wdsi/threats/malware-encyclopedia-description?Name=Trojan%3AWin32%2FLokibot.PB&ThreatID=2147831711> (accessed Apr. 23, 2024).

- [12] “202309291200_LokiBot malware analyst note_tlpclear,” Health Sector Cybersecurity Coordination Center, <https://www.hhs.gov/sites/default/files/lokibot-malware-analyst-note-tlpclear.pdf> (accessed Apr. 23, 2024).
- [13] E. Naprys, “LokiBot malware going for a song at \$80,” CyberNews, <https://cybernews.com/security/lokibot-malware-going-for-a-song-at-80> (accessed Apr. 25, 2024).
- [14] “Cybercriminals exploit Microsoft word vulnerabilities to deploy LokiBot malware,” The Hacker News, <https://thehackernews.com/2023/07/cybercriminals-exploit-microsoft-word.html> (accessed Apr. 24, 2024).